OSE Board Review Summary

How to read this

- Top 20 repos per ecosystem from the model's preview table, ordered by `score` — a 0–100 blend of value and risk (the geometric mean of the two).
- 🔵 marks the top 5 eligible repos in each section — the model's best funding candidates there.
- `eligible #N` — funding-priority rank among repos that pass all four gates (open-source license, shows funding intent, not company-backed, active). `ineligible (…)` names the blocking gate.
- Downloads — current weekly rate from the package registry, plus the repo's average annual downloads over 2021–2025 from our own source data (all packages mapped to the repo).
- C/C++ has no registry, so installs/yr come from Debian's opt-in survey panel (caps at ~230k; at the cap ≈ "on every Debian machine") and Homebrew analytics.
- "Sole publish rights" — one personal account can publish the package; if that person disappears, nobody can ship even a security fix.
- Every flag and figure was verified against live sources (GitHub/GitLab APIs, registries, sponsor listings, funding files, Open Collective); incident stories are documented in press, official records, or the maintainers' own public statements.

NPM

1. **evanw/esbuild — score 76, ineligible (no intent) · 253M dl/wk now · avg 3.0B/yr 2021–25**
   A very fast JavaScript build tool. Created 2020 by Evan Wallace, Figma co-founder/CTO (left 2021). Still a one-man project — 29 of the last 30 code changes are his. Figma's IPO made him a billionaire (~$3.1B); he donated ~⅓ of his shares. Likely the wealthiest person hand-maintaining a core npm package — and he takes no donations.

2. **moment/moment 🔵 — 75, eligible #1 · 28M dl/wk now · avg 1.0B/yr 2021–25**
   The classic JavaScript date/time library. Created 2011 by Tim Wood — who left software and is now training as a building architect in Chicago. Passed through several caretakers: Iskren Chernev (now at AI startup Deep Infra), then Maggie Johnson-Pint (Stripe, ex-Microsoft), Matt Johnson-Pint (Cloudflare) and Kunal Marwaha (quantum-computing researcher). Nobody actively maintains it — the team's real fix was getting proper date handling built into the JavaScript language itself (Maggie co-led that standards work, finalized in 2026). Hosted by the OpenJS Foundation; officially "done, not dead" since 2020.

3. **websockets/ws 🔵 — 75, eligible #2 · 219M dl/wk now · avg 3.6B/yr 2021–25**
   The standard real-time-connection (WebSocket) library for Node.js. Created 2011 by Einar Otto Stangvik — now an investigative journalist and security specialist at Norway's VG newspaper, known for exposing dark-web child-abuse networks. Sole maintainer since ~2016: Luigi Pinca (Foligno, Italy), a volunteer with no identifiable corporate sponsor.

4. **estools/escodegen — 74, ineligible (no intent) · 55M dl/wk now · avg 1.5B/yr 2021–25**
   A tool that turns analyzed JavaScript code back into source text — plumbing inside many build tools. Created 2012 by Yusuke Suzuki — now at Apple building Safari's JavaScript engine. Caretaker: Michael Ficarra (F5 Networks), who is literally one of the editors of the official JavaScript language specification. Last release 2023; dormant.

5. **terser/terser 🔵 — 73, eligible #3 · 69M dl/wk now · avg 1.6B/yr 2021–25**
   The code "minifier" that shrinks JavaScript before it ships to browsers — used in virtually every web build. Fábio Santos (Lisbon freelancer; past clients include The Economist) rescued an abandoned predecessor in 2018 and got the major build tools to switch to his fork. Solo today, funded by an Open Collective (~$3.5k/yr) plus GitHub Sponsors.

6. **xtuc/webassemblyjs — 72, ineligible (no intent) · 36M dl/wk now (top pkg) · repo avg 17.0B/yr 2021–25 (18 pkgs)**
   Tooling for WebAssembly (the browser technology for running near-native code), baked into the webpack build tool. Created 2017–18 by Sven Sauleau — Principal Engineer at Cloudflare and a member of several web-standards groups. 1,443 of ~1,700 code changes are his. Dormant since Nov 2024, yet still inside every webpack build that touches WebAssembly.

7. **eemeli/yaml 🔵 — 71, eligible #13 · 169M dl/wk now · avg 1.9B/yr 2021–25**
   The main JavaScript parser for YAML (the config-file format). Written from scratch in 2018 by Eemeli Aro, Staff Engineer at Mozilla (Helsinki), who also sits on the JavaScript standards committee and the YAML specification group. Solo: 1,565 code changes vs the runner-up's 15. Actively shipping.

8. **ljharb/qs 🔵 — 71, eligible #14 · 138M dl/wk now · avg 3.7B/yr 2021–25**
   Parses the `?key=value` part of URLs; ships inside Express, the most common Node.js web framework. Created 2011 by TJ Holowaychuk, rewritten by the hapi community in 2014 (Nathan LaFreniere, ex-npm Inc chief architect), handed in 2015 to Jordan Harband — a JavaScript standards-committee veteran (ex-Airbnb/Coinbase, now at security firm Socket) who single-handedly leads 400+ npm packages. The canonical "too much depends on one person" case — and a proven attack target: in July 2025 a phishing campaign hunting high-impact npm maintainers got a backdoored version of his "is" package (2.8M dl/wk) live for ~6 hours via a hijacked ex-co-maintainer account. qs itself was not compromised; Harband disclosed the incident himself.

9. **nodeca/js-yaml — 70, eligible #19 · 261M dl/wk now · avg 3.7B/yr 2021–25**
   The other big YAML parser for JavaScript. Started 2011 as a port of a Python library (initial author Vladimir Zapparov; early lead Alexey Zapparov, now at fintech Kikoff). Today Vitaly Puzrin alone (Israel; also author of the popular markdown-it library) — he single-handedly rewrote it in TypeScript in June 2026. History lesson attached: for years its default file-loading mode could execute code embedded in a YAML file (a hacking-toolkit module for it still exists); the 2021 rewrite made safe loading the default.

10. **aws/aws-sdk-js-v3 — 70, ineligible (company-backed) · 105M dl/wk now (top pkg) · repo avg 20.1B/yr 2021–25 (60 pkgs)**
    Amazon's official JavaScript toolkit for AWS. No individual creator — a corporate team product. Visible leads: Trivikram Kamat and George Fu. If someone leaves, Amazon staffs a replacement — which is exactly why it doesn't need outside funding.

11. **vuejs/core — 70, eligible #20 · vue 13.4M + @vue/shared 24.5M dl/wk now · repo avg 1.9B/yr 2021–25 (11 pkgs)**
    Vue, one of the world's most popular web frameworks. Evan You (ex-Google) released it in 2014 and has lived on community sponsorships since 2016; his build-tools company VoidZero (founded 2024) was acquired by Cloudflare in June 2026, and he still leads the project from Singapore. A real multi-person core team exists (Eduardo San Martin Morote maintains the companion routing/state libraries). Its Open Collective runs ~$225k/yr.

12. **prettier/prettier — 70, eligible #21 · 99M dl/wk now · avg 1.6B/yr 2021–25**

    The standard automatic code formatter for JavaScript. Created 2016–17 by James Long (ex-Mozilla/Stripe, currently independent) and Christopher Chedeau (still at Meta). It has survived two full changes of maintainers; after Sosuke Suzuki retired in Feb 2026, the primary maintainer is fisker Cheung (China). Its Open Collective (~$260k raised) pays maintainers $1.5k/month and once paid a $20k bounty for a speed improvement. Security note: in July 2025 a companion package in the same GitHub org (eslint-config-prettier, ~30M dl/wk) shipped malware for about two days after its maintainer was phished with a fake npm email — cleaned up within hours of discovery, but a live demonstration that maintainer-account security is part of the funding picture.

13. **zloirock/core-js — 70, eligible #22 · 62M dl/wk now · avg 3.7B/yr 2021–25**

    Compatibility layer that lets modern JavaScript run in old browsers; quietly present on much of the web. Denis Pushkarev, solo since 2013, works on it full-time living off donations (Open Collective, GitHub Sponsors, Patreon), based in Cyprus. Served ~10 months in prison (2020) after a fatal traffic accident — while his library kept running on much of the internet with no maintainer. His 2023 essay "So, what about money?" reset the open-source funding conversation. If he stops, it stops; last change committed today.

14. **nodeca/argparse — 70, eligible #23 · 233M dl/wk now · avg 3.5B/yr 2021–25**

    Command-line-options parser, copied from Python's standard library. Written 2012 by Eugene Shkuropat — his GitHub account is now blank, whereabouts unknown. Puzrin keeps it alive; no new version published since 2020. 510 GitHub stars, 233M weekly downloads — huge usage, near-zero visibility.

15. **facebook/regenerator — 69, ineligible (archived; company-owned per our override) · 64M dl/wk now (legacy) · avg 3.4B/yr 2021–25**

    A translator that let older browsers run modern JavaScript async features. Ben Newman wrote it at Facebook in 2013 and kept maintaining it across three later employers (now at Apollo GraphQL, NYC). Meta archived the repo in Feb 2025 and the ecosystem's main tools dropped it a month later — an orderly retirement; today's downloads are inertia.

16. **jonschlinkert/kind-of — 69, eligible #26 · 97M dl/wk now · avg 6.1B/yr 2021–25**

    A tiny "what type is this value?" utility. Jon Schlinkert (2014) and Brian Woodward — a Cincinnati duo whose thousands of micro-packages are downloaded billions of times a year, invisibly, as dependencies of dependencies. The code is finished: nothing published since 2020. Its one security scar shows why even trivial packages matter: a 2019 bug let attackers fool its type checks, with researchers demonstrating downstream injection attacks before the fix.

17. **jridgewell/sourcemaps — 69, ineligible (no intent) · 150–180M dl/wk now per pkg · repo avg 7.5B/yr 2021–25 (4 pkgs)**

    "Source maps" let developers debug the shipped, compressed version of their code — and these libraries are the layer every JavaScript build tool uses for that. Justin Ridgewell — ex-Google, now at Vercel — maintains the whole layer alone, in his spare time, deliberately unfunded (no donation channel on any of his 100 repos).

18. **ajv-validator/ajv — 69, eligible #30 · 275M dl/wk now · avg 4.7B/yr 2021–25**

    The standard library for validating JSON data. Evgeny Poberezkin, 2015 (then at MailOnline; won grants from Mozilla and Microsoft). Now founder/CEO of the SimpleX Chat messenger, so maintenance comes in bursts — he still personally shipped the 2026 security fix; Jason Ian Green handles day-to-day. 2,060 of ~2,400 human code changes are his.

19. **medikoo/es5-ext — 69, eligible #32 · 10.5M dl/wk now · avg 978M/yr 2021–25**

    A grab-bag of JavaScript utility functions from an earlier era. Mariusz Nowak (Warsaw), 2011; long-time core developer at Serverless Inc. Solo; dormant since Feb 2024. In 2022 he added an install-time anti-war message shown to users in Russian time zones — a controversial move ("protestware") that damaged trust in the package; it's still there.

20. **cssnano/cssnano — 68, eligible #35 · 14M dl/wk now (top pkg) · repo avg 16.8B/yr 2021–25 (38 pkgs)**
    The standard tool for compressing CSS stylesheets. Created 2015 by Ben Briggs, who vanished from GitHub after 2019. A "looking for new owners" notice has been open since 2019; today it's effectively Ludovico Fischer alone (active this week), with Andrey Sitnik (creator of the underlying PostCSS toolchain) holding backup publish rights as a safety net.

PyPI

1. **pyca/cryptography — 76, ineligible (no intent) · 326M dl/wk now · avg 2.6B/yr 2021–25**
   Python's core encryption library. Created Aug 2013 by Alex Gaynor and Paul Kehrer to replace an abandoned predecessor. Both still co-lead; Gaynor is now a security engineer at Anthropic. Zero ways to give the project money — verified exhaustively across all its repos. Battle-tested governance: in 2021, adding Rust to the build (a security-driven decision) broke installs on niche platforms and unleashed a firestorm — a 179-comment thread locked as "too heated," with documented abuse aimed at the maintainers — and they held the line. Now migrating off OpenSSL entirely, and per their own 2026 statements, neither lead gets paid work time for the project anymore.

2. **takluyver/jeepney — 74, ineligible (no intent) · 50M dl/wk now · avg 474M/yr 2021–25**
   A small Linux desktop-messaging library that sits under Python's password/keyring tools. Created 2017 by Thomas Kluyver — a long-time Jupyter/IPython core developer (he ported IPython to Python 3 single-handedly), now at the European XFEL research facility in Hamburg. Solo, no funding channel anywhere; quiet but alive. The set's only GitLab-hosted repo.

3. **lxml/lxml ● — 72, eligible #6 · 94M dl/wk now · avg 972M/yr 2021–25**
   The fast XML/HTML processing library for Python. Started 2004 by Martijn Faassen; Stefan Behnel has run it since the mid-2000s — he also leads Cython (a major Python-to-C compiler) alongside a day job at travel-tech firm TrustYou. Its published project income for 2024 was ~€2,826 against 94M downloads a week — one of the starkest value-versus-funding gaps anywhere.

4. **paramiko/paramiko ● — 72, eligible #9 · 35M dl/wk now · avg 590M/yr 2021–25**
   Python's SSH library (secure remote connections; used by deployment tools everywhere). Created 2003 by Robey Pointer; Jeff Forcier has maintained it since ~2012 alongside jobs (now at Reach Security). His July 2020 public plea is one of the most-cited burnout statements in open source: "*I'm burned out. I lie awake at night… crippled by guilt… making the thought of facing the issue tracker unbearable.*" The project since revived: an independent security audit was completed and version 5.0 shipped May 2026.

5. **sqlalchemy/sqlalchemy ● — 71, eligible #10 · 93M dl/wk now · avg 1.2B/yr 2021–25**
   The standard Python database toolkit. Mike Bayer created it 2005 and still leads it; he's been at Red Hat since 2014. Federico Caselli (Italy) is the second core maintainer. Founder-led governance, funded via GitHub Sponsors, Patreon and Tidelift (a service where companies pay maintainers of the software they use). Still shipping fast.

6. **tqdm/tqdm ● — 71, eligible #12 · 140M dl/wk now · avg 1.0B/yr 2021–25**
   The ubiquitous progress bar you see in Python scripts. Originated 2013 by Noam Yorav-Raphael; when he went silent in 2015, volunteers waited for his blessing, never got a reply, and the package name was eventually transferred to the community fork by PyPI's administrators — a civil but consent-less handover that shows how registry ownership actually works. Led since then by Casper da Costa-Luis — a computational physicist working freelance — with co-maintainer Stephen Larroque, a coma-science researcher at the University of Liège. Multiple funding channels; released July 2026.

7. **pallets/jinja ● — 70, eligible #15 · 155M dl/wk now · avg 1.9B/yr 2021–25**
The standard Python templating engine (how web apps generate HTML). Armin Ronacher created it 2006-08 along with the Flask web framework; he left Sentry in Mar 2025 to found a new company. Day-to-day work is done by David Lord, lead of the Pallets organization, partially paid from project donations; Pallets' money is managed by the Python Software Foundation (the nonprofit behind Python). Lord's own 2024 report is blunt: he handles ~85% of maintenance across six libraries and has had "severe burnout multiple times each of the past four years" — the income "is not enough to hire someone full time."

8. **chardet/chardet — 69, ineligible (no intent) · 40M dl/wk now · avg 904M/yr 2021–25**
Guesses the text encoding of files — old but everywhere. Based on Mark Pilgrim's ~2006 work; Pilgrim famously deleted his entire internet presence in 2011. Dan Blanchard has maintained it since 2012 around day jobs (now at Monarch Money). In Feb 2026 he rewrote it from scratch **using the Claude AI assistant** and republished it under a permissive license in place of the old restrictive one — prompting an account claiming to be the long-vanished Pilgrim (identity unverifiable) to object that he had "no right to relicense." Blanchard's code-similarity analysis showed ~0.04% overlap with the old code; no lawsuit followed, but the episode became the reference case in the press debate over "AI license laundering." Still zero funding channels.

9. **giampaolo/psutil — 69, eligible #27 · 86M dl/wk now · avg 1.2B/yr 2021–25**
Reads system stats (CPU, memory, processes) — used by TensorFlow, PyTorch, Ansible and Home Assistant. Created 2008-09 by Giampaolo Rodolà, an Italian self-taught freelancer and long-time contributor to Python itself. "Maintained by a single developer in his spare time," per its own funding page — but with the best-organized donation setup of this list: Sponsors, Open Collective, PayPal, Tidelift, plus a paid corporate-sponsor program.

10. **pypa/setuptools — 69, eligible #29 · 344M dl/wk now · avg 4.4B/yr 2021–25**
The tool that builds and installs Python packages — under nearly every Python installation. Created 2004 by Phillip Eby; led since 2013 by Jason R. Coombs (ex-YouGov, ex-Google, now Principal Engineer at Microsoft), with Anderson Bravalheri (research software engineer, University of Bristol) building major features. Governed under Python's packaging authority with Python Software Foundation backing. Its unique blast radius is documented: three times in four years (2021, 2024, 2025) a routine cleanup release broke package installs across the ecosystem — the 2025 one broke ~12,000 packages including requests and was rolled back within five hours — drawing published criticism that the project deprecates too aggressively for infrastructure this load-bearing.

11. **grahamdumpleton/wrapt — 68, eligible #36 · 108M dl/wk now · avg 1.3B/yr 2021–25**
A low-level tool for safely wrapping and instrumenting Python code — monitoring products are built on it. Created 2013 by Graham Dumpleton (Sydney) — ex-New Relic/Red Hat/VMware, laid off in the Broadcom acquisition and currently unemployed per his Feb 2026 blog. Strictly solo yet very active (version 2.0 nearly out); has a live donations page that "doesn't pay the bills." Arguably the review's highest funding-leverage case: money here changes a real person's situation right now.

12. **boto/botocore — 68, ineligible (company-backed) · 333M dl/wk now · avg 5.1B/yr 2021–25**
The engine of Amazon's official Python tools for AWS. Created 2012 by Mitch Garnaat, who had built the beloved community version before joining Amazon (he left in Aug 2025). Now an anonymous team product — recent code changes are all from a release robot. Amazon pays for it; that's why it's ineligible.

13. **python-pillow/pillow — 68, eligible #39 · 118M dl/wk now · avg 1.0B/yr 2021–25**
Python's standard image-processing library. Descends from PIL by Fredrik Lundh (1995; he died in 2021 — without the 2010 community fork, a top-10 dependency would have died with its author). Alex Clark led that fork (now at MongoDB); today's leads are Andrew Murray (7,215 code changes) and Hugo van Kemenade (Helsinki — also the release manager for Python 3.14/3.15 itself), with Eric Soroos on security. A genuine multi-person team — the healthiest succession setup in the Python list. The funding reality is public and sobering: the maintainers have disclosed that their Tidelift arrangement started at ~$83/month each — low four figures a year for one of Python's most-downloaded packages.

14. **coveragepy/coveragepy — 67, eligible #40 · 72M dl/wk now · avg 778M/yr 2021–25**
Measures which lines of code your tests actually test — a fixture of every Python project. Stewarded by Ned Batchelder since 2004 — 22 years, 6,915 code changes vs 21 for the next human. Batchelder: edX, Anthropic (2024), now on Netflix's Python team; long-time leader of the Boston Python community.

15. **httplib2/httplib2 — 67, ineligible (no intent) · 40M dl/wk now · avg 519M/yr 2021–25**
An early Python HTTP client — superseded by newer libraries, but Google's official API client still requires it. Created ~2006 by Joe Gregorio (long-time Google engineer, now at Meta), who handed it to the community in 2016; Sergey Shepelev has maintained it since, still releasing. No way to fund it exists.

16. **mrabarnett/mrab-regex — 67, ineligible (no intent) · 94M dl/wk now · avg 643M/yr 2021–25**
A more powerful text-pattern (regex) engine than Python's built-in one; pulled in by many AI/language-processing stacks. Matthew Barnett has maintained it alone for ~17 years — and is near-anonymous: no name, employer or biography anywhere public (likely UK-based). Very active. High-performance C code, one invisible person deep.

17. **legrandin/pycryptodome — 67, ineligible (no intent) · 45M dl/wk now (both pkgs) · avg 661M/yr 2021–25**
A widely-used Python encryption library, revived in 2014 from an abandoned predecessor by Helder Eijs — effectively solo and professionally near-anonymous (public location: "Europe"). Alive, with zero funding channels. The predecessor's fate is the strongest cautionary tale in this review: PyCrypto's maintainer went silent in 2013 and a critical remote-code-execution flaw (severity 9.8/10) was **never fixed in any released version** — the abandoned package still sits on the registry with the hole in it.

18. **pallets/werkzeug — 67, eligible #49 · 58M dl/wk now · avg 1.2B/yr 2021–25**
The plumbing under Flask, one of Python's two big web frameworks. Also created 2007 by Ronacher; today David Lord is the working maintainer alongside a full-time job, on a steady release pace. Strongest funding setup of the Pallets projects: organization-level Sponsors, Tidelift, and Python Software Foundation money management.

19. **grantjenks/python-sortedcontainers — 67, eligible #51 · 62M dl/wk now · avg 589M/yr 2021–25**
Fast sorted data structures in pure Python. Grant Jenks, 2014 — ex-Microsoft, ex-LinkedIn, now at OpenAI. Textbook dormancy: 623 of 650 code changes are his, last release May 2021, 11 proposed fixes sitting unanswered — including a volunteer offering regular maintenance time, waiting in the issue tracker since July 2026. Its funding-intent flag hangs on an Open Collective with 5 backers and $0/yr income.

20. **pypa/distlib — 67, eligible #53 · 70M dl/wk now · avg 863M/yr 2021–25**
Packaging plumbing bundled inside pip itself (Python's installer) — 65 GitHub stars, 70M downloads a week. Vinay Sajip (UK) wrote it ~2012; he also wrote Python's built-in logging system. Effectively solo, but under the Python packaging authority's umbrella with the Python Software Foundation behind it.

Crates

1. **serde-rs/serde ● — 73, eligible #4 · ~17.8M dl/wk now · avg 315M/yr 2021–25**
   Rust's standard way to convert data to/from formats like JSON. Created Nov 2013 by Erick Tryzelaar; David Tolnay has been the de-facto sole maintainer since ~2016 — famously private (his GitHub profile shows an encryption-key fingerprint instead of an employer), reported to have worked on Meta's Rust infrastructure. Funded through his personal GitHub Sponsors page (125 sponsors). The Aug 2023 governance stress test: he shipped a pre-built binary inside the package with no opt-out; when the community objected over supply-chain safety (and Linux distributions like Fedora said policy forbade them redistributing it), he initially answered that the binary was "the only supported way" — then reversed within weeks. The same year, he published a personal apology acknowledging he had driven the internal skepticism that led Rust leadership to downgrade an invited conference keynote, the trigger of the project's biggest 2023 governance crisis. Both stories cut the same way: enormous competence, one person's judgment as the single point of failure.

2. **retep998/winapi-rs ● — 73, eligible #5 · ~6.5M dl/wk now · avg 143M/yr 2021–25**
   The community's original Windows bindings for Rust. Created 2014 by Peter Atashian. Effectively abandoned: last release June 2020, and an issue titled "Is winapi abandoned?" has been open since 2020. It still ranks eligible #5 because the model's `active` check only asks "archived or end-of-life?" — technically neither. Atashian alone holds publish rights and is inactive: 6.5M weekly downloads with no security-fix path today. **Recommend manually marking it end-of-life to remove it from the fundable list.**

3. **microsoft/windows-rs — 72, ineligible (Microsoft-owned) · ~29.2M dl/wk now (windows-sys) · avg 1.1B/yr 2021–25 (24 pkgs)**
   Microsoft's official Windows bindings for Rust, created 2019 by Kenny Kerr. Ineligible by design — Microsoft pays for it. Worth knowing anyway: despite the corporate umbrella, Kerr personally wrote all 30 most-recent code changes and is personally the only account that can publish the main package — even Microsoft's own toolkit releases through one individual, not a team account.

4. **dtolnay/syn ● — 72, eligible #7 · ~29.1M dl/wk now · avg 246M/yr 2021–25**
   The parsing engine behind Rust's code-generation system — roughly 65% of all published Rust packages depend on it, directly or indirectly. Tolnay again: 28 of the last 30 code changes are his, he alone can publish it, and the funding channel is the same single Sponsors page as serde. Concretely: one person's availability underpins four of this list's rows at once (serde #4, syn #7, proc-macro2 #41, serde_json #60).

5. **crossbeam-rs/crossbeam ● — 72, eligible #8 · ~12.2M dl/wk now · avg 331M/yr 2021–25**
   The toolkit for safe multi-threaded programming in Rust. Created 2015 by Aaron Turon of Mozilla's Rust team (now at Fastly). Every historical lead has moved on — one to a professorship at KAIST in Korea (Jeehoon Kang, also chief scientist of an AI-chip startup); another, Stjepan Glavina — once its most prolific maintainer — wiped his GitHub repositories around 2021 and left public open-source work without explanation. The person actually maintaining it today is Taiki Endo (69 of ~89 changes in the last year), and the only way to fund the project is his personal Sponsors page.

6. **toml-rs/toml ● — 71, eligible #11 · ~13.0M dl/wk now · avg 295M/yr 2021–25**
   Reads the configuration file at the heart of every Rust project. Originally by Alex Crichton (2014); led today by Ed Page, who wrote 355 of the last 436 code changes while also serving on the team behind Rust's package manager. His employer Futurewei explicitly pays for his open-source time — a rare "paid to maintain" case. Eric Huss co-maintains.

7. **rust-lang/regex — 70, eligible #17 · ~15.1M dl/wk now · avg 421M/yr 2021–25**
   Rust's standard text-pattern engine. Created 2014 by Andrew Gallant (also author of the popular ripgrep search tool). The repo lives under the official rust-lang organization with the Rust Foundation (nonprofit) behind it — but in practice it's one person: 50 of the last 67 changes are Gallant's. His employer chain: Salesforce → Astral (2024) → OpenAI, which acquired Astral in Mar 2026. Donations go to his personal Sponsors page.

8. **bytecodealliance/rustix — 70, eligible #18 · ~17.1M dl/wk now · avg 108M/yr 2021–25**
   The safe layer between Rust programs and the operating system — invisible infrastructure under much of modern Rust. Created 2020 by Dan Gohman (a WebAssembly pioneer; at Fastly). The model marks it fundable because a real nonprofit foundation (Bytecode Alliance) hosts the project — but that foundation is funded by corporate memberships, and there is literally no account anywhere a donor could pay into. If the fund wanted to pay this project, there'd be nowhere to send the money today.

9. **rust-lang/futures-rs — 70, eligible #24 · ~11.2M dl/wk now · avg 728M/yr 2021–25 (17 pkgs)**
   The building blocks of asynchronous (non-blocking) programming in Rust. Created 2016 by Alex Crichton (now Principal Engineer at Akamai) and Aaron Turon. Actual maintenance today is again Taiki Endo. Like rustix, it counts as fundable only because of foundation hosting — the project itself has no donation channel.

10. **time-rs/time — 69, eligible #25 · ~11.1M dl/wk now · avg 229M/yr 2021–25**
    Rust's main date/time library, revived and solely maintained by Jacob Pratt since 2019 (95 of the last 100 changes). Funded via Sponsors, Liberapay and PayPal. Known for a July 2024 incident where a new version of the Rust compiler accidentally broke builds of nearly every released version of this library — a wake-up call for the whole ecosystem about compatibility.

11. **gitoxidelabs/gitoxide — 69, eligible #31 · ~0.7M dl/wk now (top pkg) · repo avg 224M/yr 2021–25 (59 pkgs)**
    A from-scratch reimplementation of Git in Rust, written essentially alone by Sebastian Thiel (Berlin; ex-film-VFX engineer; also the last remaining maintainer of the equivalent Python library since ~2009). Full-time on it since 2020, living on GitHub Sponsors, an Open Collective ($20.6k in 2025 — a budget our pipeline was silently missing until this week's fix), a Rust Foundation grant, and the Astral OSS Fund. Rust's own package manager is adopting it. 70 packages in one repo, one dominant maintainer.

12. **clap-rs/clap — 69, eligible #34 · ~15.2M dl/wk now · avg 354M/yr 2021–25**
    How Rust programs read command-line options; arguably the most-downloaded such tool in any language (958M lifetime). Created 2015 by Kevin Knapp, who stepped back during a multi-year stall; Ed Page rescued it, shipped version 3.0 in Dec 2021 (paid for by his employer Futurewei), and leads today. Healthier funding shape than most: the organization has its own Sponsors listing plus an Open Collective, rather than one person's page.

13. **rust-cli/anstyle — 68, eligible #37 · ~12.5M dl/wk now · avg 323M/yr 2021–25 (10 pkgs)**
    Terminal-colors plumbing under clap, created 2022 by Ed Page in a community organization. One data quirk: GitHub labels the repo's language "HTML" because test files outweigh the actual Rust code by bytes — cosmetic, not an error.

14. **dtolnay/proc-macro2 — 67, eligible #41 · ~20.4M dl/wk now · avg 167M/yr 2021–25**
    A compatibility layer beneath syn — 1.33B lifetime downloads. Same story as syn: Tolnay solo, sole publish rights, one Sponsors channel shared across his whole portfolio.

15. **taiki-e/portable-atomic — 67, eligible #50 · ~8.0M dl/wk now · avg 41M/yr 2021–25**
    Low-level concurrency support for small embedded devices — load-bearing for Rust on microcontrollers. Created 2022 by Taiki Endo — the third project on this list where he is the working maintainer. No public employer; income is GitHub Sponsors plus targeted grants (Astral OSS Fund, Microsoft's open-source fund). Funding him effectively funds three of this list's rows at once.

16. **serde-rs/json — 66, eligible #60 · ~17.6M dl/wk now · avg 128M/yr 2021–25**
THE standard JSON library for Rust (1.06B lifetime downloads), maintained by Tolnay since ~2016. The repo itself offers no donation channel; it counts as fundable because a sibling repo of the same owner (serde) declares one — reasonable, since the owner is the same person.

17. **google/zerocopy — 66, ineligible (Google-owned) · ~15.4M dl/wk now · avg 120M/yr 2021–25**
Google's library for handling raw memory safely in Rust, built by Joshua Liebow-Feeser (Google) with co-lead Jack Wrenn (ex-AWS, now also Google). Ineligible because company-owned — and unusually safe for it: both maintainers sit on one corporate payroll.

18. **alexhuszagh/rust-lexical — 66, ineligible (no intent) · ~1.7M dl/wk now · avg 85M/yr 2021–25**
High-performance number parsing whose algorithms made it into Rust's standard library. One maintainer, Alexander Huszagh (biochemistry PhD background), with a real scare on record: bugs reported in 2023 sat unfixed while the project was dormant, drawing a public security advisory, until he returned and rewrote it. He offers no way to fund him at all — here, the *absence* of a donation channel is itself the risk signal.

19. **rayon-rs/rayon — 66, ineligible (no intent) · ~7.6M dl/wk now · avg 111M/yr 2021–25**
The standard "use all CPU cores" library for Rust. Created 2014 by Niko Matsakis (one of the chief designers of the Rust language itself; Senior Principal Engineer at AWS), with Josh Stone of Red Hat as day-to-day lead. Deliberately no donation surface anywhere: two well-salaried engineers maintain it as part of their professional lives. Ineligible — correctly, and probably permanently.

20. **burntsushi/memchr — 66, eligible #63 · ~20.0M dl/wk now · avg 134M/yr 2021–25**
Hardware-accelerated text search — the hot inner loop under Rust's regex engine and much of the ecosystem (1.13B lifetime downloads). Gallant's solo project; very active; Sponsors live. Note for the model: his employer is now OpenAI (via the Astral acquisition), but the repo is personally owned, so "not company-backed" correctly stays true — worth revisiting only if maintainer employment ever becomes a factor.

C/C++

1. **gnutls/gnutls — 71, ineligible (no funding channel) · debian 193k (84% of panel) + brew 1.55M installs/yr**
An encryption (TLS) library used across the Linux world. Created ~2000 by Nikos Mavrogiannopoulos; led since 2020 by Daiki Ueno, a Red Hat principal engineer — nearly all top contributors are Red Hat staff, but the project belongs to the GNU free-software project, not Red Hat, so "not company-backed" holds. Its history carries two lessons: in 2014 an error-handling bug meant it had been accepting forged security certificates for ~9 years (open source's own "goto fail" moment), and back in 2012 its founder publicly pulled the project off the Free Software Foundation's infrastructure in a governance dispute — it has run independently since. And still: no donation account of any kind exists.

2. **yaml/libyaml ● — 70, eligible #16 · debian 158k + brew 535k installs/yr**
The C parser for YAML config files, sitting beneath most languages' YAML support. Written 2006 by Kirill Simonov (long moved on); maintained by the yaml community organization: Ingy döt Net (co-creator of the YAML format itself) and Tina Müller (SUSE). The funding gate passes only because Müller has a personal GitHub Sponsors page — the project declares nothing. Releases are glacial (stable in 2020, a release candidate finally in Apr 2026), but it isn't archived or end-of-life, so `active` holds per spec.

3. **lz4/lz4 — 69, ineligible (no funding channel) · debian 213k + brew 1.83M installs/yr · 11.9k★**
Extremely fast compression used in the Linux kernel, databases and file systems. Yann Collet created it in 2011 as a hobby (he was a project manager who wrote chess engines for fun), then joined Meta in 2015 where he built its successor (zstd, #19 below) and still works. lz4 remains his personal repo with deliberately no way to fund it.

4. **libexpat/libexpat ● — 69, eligible #28 · debian 230k (at panel cap) + brew 425k installs/yr**
   An XML parser embedded in Python, Firefox, Chromium, PHP, Perl and Git. Created 1997-98 by James Clark; today security releases are run largely single-handed by Sebastian Pipping (Berlin). The project's own documentation carries a standing warning that it is "understaffed and without funding" — and Pipping has documented the consequence: a complex, non-public security bug sat unfixed for months because he works alone and unpaid, and attackers may have found it independently in the meantime. Fragile detail: its funding-intent flag rests entirely on one manual override row in our data (his profile asks for donations to a European free-software nonprofit rather than any Sponsors page).

5. **libjpeg-turbo/libjpeg-turbo ● — 69, eligible #33 · debian 189k + brew 1.80M installs/yr**
   The JPEG decoder in every browser, Android and iOS. A solo project since its 2010 fork by Darrell Commander (Virginia). A rare governance story where the fork beat the "official" project: the original JPEG group's new leadership pushed an incompatible format extension that international standards bodies rejected — and it's Commander's fork that is now the official ISO/ITU reference implementation of JPEG. The most deliberately organized funding setup in this list: organization Sponsors listing, funding file, and a published machine-readable funding manifest.

6. **util-linux/util-linux — 67, ineligible (no funding channel) · debian 230k (at cap) + brew 239k installs/yr**
   The basic Linux command-line tools — mount, fdisk, login. Karel Zak (Red Hat principal engineer) has been sole lead for ~20 years and wrote 26 of the last 30 code changes. No donation surface exists anywhere; maintenance is simply part of his Red Hat job. (Its home on kernel.org is hosting, not funding.)

7. **curl/curl ● — 67, eligible #47 · debian 202k + brew 1.06M installs/yr · 42.4k★**
   Daniel Stenberg's file-transfer tool, present in an estimated 20+ billion devices (cars, TVs, consoles, every OS). He has worked on curl full-time since 2019, funded by support contracts through security firm wolfSSL plus the project's GitHub Sponsors and Open Collective — the clearest "funding actually sustains a person" case in the whole review. wolfSSL employs him but doesn't own curl, so "not company-backed" is correct.

8. **systemd/systemd ● — 67, eligible #52 · debian 229k (at cap) + brew 72k installs/yr · 16.5k★**
   The startup-and-services manager of mainstream Linux. Created 2010 by Lennart Poettering at Red Hat; he moved to Microsoft in 2022 and left in 2026 to co-found a startup — still the lead. The project was born in flames: it became the most polarizing software in Linux history, and in 2014 Poettering wrote that open source had become "quite a sick place to be in," describing sustained hate mail and stop-work petitions (a famously reported "crowdfunded hitman" item traces back to an IRC joke, but the harassment campaign itself is well documented); the same year Linus Torvalds publicly banned a systemd co-author's kernel contributions in a dispute over debugging behavior. Governed today by a maintainer committee staffed heavily by Red Hat and Microsoft employees, with the project's money held by Software in the Public Interest, a US nonprofit — corporate-staffed, not corporate-owned.

9. **madler/zlib — 67, ineligible (no funding channel) · debian 230k (at cap) + brew 890k installs/yr**
   Plausibly the most-deployed compression library on Earth — in the Linux kernel, every browser, PNG images, Git, and endless device firmware. Mark Adler (1995, with Jean-loup Gailly) spent his career as a NASA/JPL Mars-program architect, then Apple, now retired; funding was never the model and no channel exists. Its scariest incident was a maintenance failure, not a coding one: a memory-corruption bug was *fixed* in 2018 — but no release carrying the fix shipped for four years, until a researcher revived it with a working exploit in 2022 and the whole industry had to emergency-patch.

10. **harfbuzz/harfbuzz — 66, eligible #56 · debian 165k + brew 2.50M installs/yr · 5.9k★**
    The text-rendering engine that draws the letters you're reading — used by Chrome, Android, LibreOffice and both major Linux desktops. Behdad Esfahbod (Red Hat → Google → Facebook → independent consultant) wrote most of it. In January 2020, visiting Iran for his grandfather's funeral, he was arrested by Revolutionary Guard intelligence, held and interrogated for about a week while agents went through his online accounts, and released only on the condition that he spy on Iranian activists abroad — he refused, ignored their follow-ups, and went public with the story. Co-maintainer Khaled Hosny is a Cairo physician-turned-font-engineer, paid by the LibreOffice foundation since 2023. The funding channel is its Open Collective; much day-to-day code arrives from Google-employed contributors.

11. **mpfr/mpfr — 66, eligible #61 · debian 157k + brew 639k installs/yr**
    A high-precision math library that the GCC compiler — which builds most of the Linux world — cannot be built without. Developed since 1999 by researchers at INRIA, France's national computer-science institute (Paul Zimmermann, Vincent Lefèvre). The archetype of taxpayer-funded research software: fundable in our model via the institution, with no donation channel. Won a French open-science prize in 2025; active today.

12. **besser82/libxcrypt — 66, ineligible (no funding channel) · debian 151k + brew 191k installs/yr**
    The password-hashing library virtually every Linux login goes through. Two people: Björn Esser (Fedora volunteer packager, employer unknown) and Zack Weinberg (teaches computer systems at Carnegie Mellon). Zero funding surface, quiet but alive — password security for the Linux world, one hobbyist deep.

13. **md/tcp-wrappers — 65, eligible #74 · debian 229k (at cap), no brew**
    A 1990s network access-control layer still built into Unix services everywhere. Original author Wietse Venema (also created the Postfix mail server; IBM Research → Google) froze the code in 1997; what our pipeline tracks is Debian's maintained copy, packaged by Marco d'Itri (Debian volunteer since 1997; network architect at Italian hosting firm Seeweb). There is no upstream entity to fund — its eligibility rides entirely on Debian's nonprofit status. A philosophical test case: funding it means funding Debian.

14. **nlnetlabs/unbound — 65, eligible #75 · debian 64k + brew 1.64M installs/yr · 4.7k★**
    A DNS resolver (the internet's address book lookup) run by internet providers worldwide. Built and maintained since 2007 by NLnet Labs, a genuine Dutch nonprofit foundation funded by donations, EU grants, and support contracts — the cleanest institutional case in the review: real staff team, live donation channel, no single-person risk.

15. **bdwgc/bdwgc — 65, ineligible (no funding channel) · debian 85k + brew 541k installs/yr**
    An automatic memory manager used inside many programming-language runtimes. Created by Hans Boehm (a storied computer scientist: Xerox PARC → SGI → HP → Google); maintained for the last decade by Ivan Maidanski (Moscow, employed at Samsung). Zero funding channels of any kind.

16. **libffi/libffi — 65, eligible #79 · debian 95k + brew 678k installs/yr · 4.3k★**
    The bridge that lets languages like Python and Ruby call into C code — beneath every such connection. Anthony Green wrote it in 1996 and is still at Red Hat today. No donation channel of its own — it counts as fundable because its hosting is fiscally sponsored by Software Freedom Conservancy, a nonprofit. Actively released.

17. **xorg/lib/libxdmcp — 65, eligible #88 · debian 228k (near cap) + brew 978k installs/yr**

A tiny X11 helper implementing a 1980s protocol for logging into a graphical session on a *remote* machine — a thing almost nobody does any more. It is on essentially every Linux desktop for a pure plumbing reason: `libxcb`, which every X11 program links, depends on it. In practice it is one man: Alan Coopersmith, a Solaris architect at **Oracle** and co-lead of the X.Org security team, has authored every commit since 2022 but one; releases run 2015, 2019, 2022, 2024. Its CVE history is the reason to care — until 2019 it generated session keys from the process id XORed with the clock, which is to say guessably. The eligibility verdict is formally right (X.Org is nonprofit-hosted, its money at Software Freedom Conservancy) but worth reading carefully: **the labour here is donated by an Oracle employee as part of his day job.** Funding it means funding X.Org/Conservancy, or paying a new person — not topping up an existing independent maintainer.

18. **gnome/pango — 64, eligible #99 · debian 161k + brew 1.14M installs/yr**

The text-layout library of the GNOME Linux desktop. Created 1999 by Owen Taylor (still at Red Hat); led today by Matthias Clasen, Red Hat's desktop-team manager. In practice: a GNOME Foundation library maintained on Red Hat payroll time; fundable via the GNOME Foundation, since the project has no channel of its own.

19. **facebook/zstd — 63, ineligible (company-backed) · debian 195k + brew 1.91M installs/yr**

The compressor that has been quietly replacing gzip across the industry: `.zst` files, the Linux kernel and btrfs, Fedora and Arch package compression, and now an IETF-standard way for websites to compress what they send you. Yann Collet again (see lz4, #3) — open-sourced 2016, with Nick Terrell; both at Meta, and the commit log is unambiguous (Collet 5,540, Terrell 1,226, the next names also Meta). Correctly excluded as company-backed, and healthy — though the cadence has slowed to a mature crawl (last release Feb 2025). The observation for a funder is the mirror image of the usual one: a format now baked into the Linux kernel and the HTTP spec has no independent home at all, and its bus factor is one company's headcount decision.

20. **gnome/libxml2 — 63, eligible #119 · debian 228k (near cap) + brew 521k installs/yr**

The XML parser under effectively everything — Python, PHP, PostgreSQL, Apple's operating systems. Created ~1998 by Daniel Veillard. **The fragility headline of this ecosystem:** sole unpaid maintainer Nick Wellnhofer announced in June 2025 he'd stop giving security issues special confidential treatment ("treated like any other bug"), stepped down entirely in September, and the project sat briefly labeled "unmaintained with known security issues" before two brand-new volunteers took over in Dec 2025. It counts as active today — but it's running on newcomers with essentially no funding history beyond a one-off Google donation.

Observations

1. **The unit of risk is a person, not a repo.** Roughly 50 of the 80 rows are effectively maintained by one individual (npm 12/20, PyPI ~13/20, crates 16/20, C/C++ ~13/20) — and in crates the concentration goes further: the whole top-20 collapses to ~8 humans, with David Tolnay alone under 4 rows, Ed Page under 3, Taiki Endo the working maintainer of 3, and David Lord carrying both Pallets rows in PyPI. Funding decisions made per person would cover more of this list than decisions made per repo.

2. **Each ecosystem funds differently.** npm runs on personal GitHub Sponsors pages and a few large Open Collectives (prettier, core-js, vue); PyPI adds a real institutional layer (the Python Software Foundation manages several projects' money; Tidelift pays maintainers on 8 of 20 rows) that provides succession, not just cash; crates is personal-sponsorship-dominant, with foundations that host projects but can't receive money for them, plus a visible grants scene (Astral, Microsoft, Rust Foundation); C/C++ barely has channels at all — eligibility there mostly means some institution (a Linux nonprofit, GNOME, INRIA, Debian) stands somewhere behind the repo.

3. "**Eligible**" **does not always mean** "**payable.**" At least 10 eligible rows (mpfr, tcp-wrappers, pango, libffi, libxdmcp, futures-rs, rustix among them) qualify because a nonprofit institution backs them — while offering no account a funder could actually pay into. Funding them means funding Debian, GNOME, INRIA, X.Org, or a foundation. If the fund intends to write checks, the model should distinguish "a payable channel exists" from "an institution is behind it."

4. **The no-funding-channel cluster (18 of 80) splits into three very different stories.** Deliberate refusal by the financially secure (esbuild's post-IPO billionaire, well-salaried engineers at Meta, AWS, Red Hat, a retired NASA architect); security-critical code nobody *can* pay (Python's main encryption library at 326M downloads/week, the password-hashing library of Linux, two more crypto/text engines — the scariest bucket, since money can't reach them without direct outreach); and true neglect (escodegen, webassemblyjs — no channel *and* no activity). Only the third bucket is a discovery gap; the first two are accurate reads of reality.

5. **The** "**active**" **flag masks dormancy and abandonment.** winapi-rs sits at eligible #5 abandoned since 2020 (recommend manually marking it end-of-life — the one concrete action item); moment ranks #1 in npm while officially "done" since 2020; seven more rows pass the gate with 2–6-year release gaps; tcp-wrappers ships code frozen since 1997. A staleness signal (age of last release or code change) would materially reorder every ecosystem's list.

6. **Succession works only where an institution catches the handoff.** Clean transitions ran through structures: prettier (paid maintainer stipends), qs (community org → new lead), setuptools and the Pallets projects (Python's packaging and foundation umbrellas), Pillow (a real multi-person team), unbound (foundation staff). Where there was no structure, projects survived on luck — one volunteer showing up — or nearly died (libxml2, late 2025). And the healthiest-funded solo projects (core-js, curl, gitoxide) are still one-person shows: money sustains the person, not a structure that survives them.

7. **Maintainer employment is the next gray zone.** The company-ownership rule works (AWS, Microsoft, Google, Meta repos correctly excluded), but a growing set of nominally independent projects have maintainers on Big-Tech payroll: the regex/memchr author now at OpenAI, Vue's creator at Cloudflare, curl's author funded through wolfSSL, lz4's at Meta, libXdmcp's sole committer at Oracle, several C-library leads on Red Hat time. Today the flags are correct — employment isn't ownership — but the fund should decide deliberately whether "salaried elsewhere" lowers funding priority. libXdmcp is the sharpest version: it passes as nonprofit-hosted (X.Org), yet every line of it is written by one Oracle employee on company time.

8. **Where funding would change the most right now:** wrapt (its maintainer lost his VMware income in the Broadcom layoffs and is job-hunting), libxml2 (post-crisis, new volunteers, no funding history), gitoxide and core-js (people living on donations), lxml (~€2,826/yr against 94M downloads/week), and libjpeg-turbo (solo, critical, already set up to receive money). Conversely, the top of the score list (esbuild, moment, winapi-rs) is where funding would change the least.

9. **The model cannot see nine of the most critical C libraries in existence — and bzip2 is how we found out.** Scope is restricted to repos hosted on GitHub or GitLab, because that is where the per-year commit anchors and the OpenSSF/issue-tracker signals come from. Everything on a classic self-hosted git server is therefore invisible: **glibc, binutils-gdb, readline, gettext, libunistring, libgpg-error, qt5** (sourceware, GNU Savannah, gnupg.org, code.qt.io) — and now bzip2, whose canonical home is sourceware.org and which is *actively maintained there* (last commit two days ago). bzip2 briefly appeared at the top of this C/C++ list only because the model had latched onto an abandoned GitLab fork of it; pointing it at the true upstream is correct and drops it out of scope entirely. glibc alone — the C library every Linux program on Earth links against — makes this the most consequential known limitation in the model. It is a scope decision, not a data bug, and it deserves its own piece of work.